

État des lieux du projet

SEO · Sécurité · CI/CD · Fonctionnalités

Rapport synthétique

Analyse du projet associatif au 27 juillet 2026, fondée sur le code, les modèles, les routes et la configuration présents dans le dépôt.

Synthèse

Le projet dispose désormais d'un socle fonctionnel cohérent pour une association locale : présentation publique, actualités, comptes, profils, réservations de tables, cotisations, administration, journal d'activité et gestion de l'Assaut de Bruay. L'architecture Express, EJS, Sequelize et PostgreSQL reste simple à maintenir et correspond bien au choix MVC du projet.

Les priorités ne sont plus de multiplier les pages, mais de préparer une mise en production fiable. Les efforts les plus rentables concernent le SEO technique, le durcissement HTTP, les tests automatisés et la fiabilisation des parcours déjà créés.

Priorités recommandées

- Priorité 1 : durcir la sécurité de production et retirer les documents internes du dossier public.
- Priorité 2 : créer une chaîne de tests et de déploiement reproductible.
- Priorité 3 : rendre chaque page publique identifiable par les moteurs de recherche.
- Priorité 4 : compléter les notifications, la récupération de compte et le suivi de l'Assaut de Bruay.

SEO

État actuel

Le site utilise des vues EJS rendues par le serveur. Le contenu principal est donc présent directement dans le HTML et ne dépend pas d'un framework JavaScript côté client. C'est une bonne base pour l'indexation, la rapidité d'affichage et l'accessibilité.

Les actualités disposent de pages individuelles et la page d'accueil affiche les publications récentes. Le site possède également des pages À propos, Contact et Mentions légales qui renforcent sa légitimité locale.

En revanche, toutes les pages utilisent actuellement le même titre « NordStrat - Association de jeux ». Aucun système de titre ou de description propre à chaque page n'est visible. Aucun fichier robots.txt, sitemap XML, URL canonique, métadonnée Open Graph ou donnée structurée Schema.org n'a été identifié.

Risques

- Les moteurs de recherche distinguent mal les actualités, l'association et les événements.
- Les résultats Google risquent d'utiliser des extraits générés automatiquement et peu attractifs.
- Les partages Facebook ou Discord ne disposent pas d'une image et d'un résumé maîtrisés.
- Les nouvelles actualités sont moins faciles à découvrir sans sitemap.
- Le nom local, Bruay-sur-l'Escaut, n'est pas exploité systématiquement dans les titres et descriptions.

Améliorations proposées

- Permettre à chaque contrôleur de transmettre un titre, une description et éventuellement une image sociale à la vue header.
- Ajouter une URL canonique et les métadonnées Open Graph sur les pages publiques.
- Créer robots.txt et un sitemap dynamique contenant les pages publiques et les actualités.
- Ajouter des données Schema.org de type Organization, NewsArticle et Event.
- Utiliser des titres locaux explicites, par exemple « Nord Stratégie, jeux de figurines à Bruay-sur-l'Escaut ».
- Définir une image sociale par défaut et utiliser l'image de l'article pour les actualités.
- Vérifier la hiérarchie des titres H1, H2 et les textes alternatifs des images.
- Ajouter Google Search Console ou un équivalent respectueux de la vie privée après la mise en ligne.

Niveau de priorité

Élevé avant l'ouverture publique. Le coût est modéré et le bénéfice est durable, notamment pour les actualités et l'Assaut de Bruay.

Sécurité

Points déjà solides

- Mots de passe hachés avec bcrypt et longueur contrôlée.
- Sessions stockées dans PostgreSQL avec cookies HttpOnly et SameSite.
- Régénération de la session après authentification.
- Protection CSRF sur les formulaires.
- Vérification serveur des rôles et protection globale des routes administratives.
- Limitation des tentatives de connexion, d'inscription et de contact.
- Requêtes Sequelize et SQL paramétrées.
- Contrôle du type, du contenu et de la taille des images.
- Anonymisation des comptes et protection du dernier administrateur.
- Journal administratif immuable sans collecte d'adresse IP.

Points à améliorer

- Helmet n'est pas installé et les principaux en-têtes HTTP de sécurité ne sont pas configurés.
- Express peut encore révéler sa technologie avec X-Powered-By.
- La configuration trust proxy n'est pas définie pour un futur reverse proxy.
- La vérification de l'adresse e-mail et la réinitialisation du mot de passe sont absentes.
- Les administrateurs ne disposent pas encore d'une authentification renforcée.
- Les autres sessions ne sont pas invalidées systématiquement après un changement de mot de passe ou d'e-mail.
- Les limiteurs utilisent vraisemblablement la mémoire du processus et seront remis à zéro au redémarrage.
- Des documents de travail et fichiers Zone.Identifier sont présents dans public et peuvent être exposés.
- Le fichier .env doit disposer de permissions strictes sur le serveur.
- Aucun audit automatique des dépendances n'est intégré au projet.

Améliorations proposées

- Installer Helmet, désactiver X-Powered-By et préparer une politique CSP.
- Configurer HTTPS, HSTS et trust proxy selon l'hébergement retenu.
- Sortir immédiatement les PDF internes et fichiers de travail du dossier public.
- Ajouter confirmation d'e-mail, mot de passe oublié et jetons à usage unique.
- Invalider les anciennes sessions après toute modification sensible du compte.
- Prévoir une authentification à deux facteurs pour les administrateurs.
- Stocker les limites de requêtes dans PostgreSQL ou Redis en production.
- Utiliser un compte PostgreSQL applicatif limité, distinct du propriétaire des migrations.
- Réencoder les images téléversées pour retirer les métadonnées et limiter leurs dimensions.
- Ajouter des tests d'autorisation, de CSRF, d'upload et de contrôle d'accès.

Niveau de priorité

Très élevé avant la mise en production. Le socle applicatif est sain, mais la configuration HTTP et l'exploitation du serveur doivent encore être durcies.

CI/CD

État actuel

Le projet possède uniquement les commandes de développement, de compilation CSS en mode surveillance et de démarrage du serveur. Aucun script de test, lint, contrôle de format, migration ou build de production n'est déclaré.

Aucun workflow GitHub Actions, fichier Docker, pipeline de déploiement ou environnement de préproduction n'a été identifié. Les migrations SQL sont appliquées manuellement.

Risques

- Une erreur de syntaxe ou une régression peut être poussée sans contrôle.

- Le CSS peut ne pas correspondre aux vues déployées.
- Une migration oubliée peut provoquer une erreur interne en production.
- Le déploiement dépend de manipulations manuelles difficiles à reproduire.
- Aucun retour automatique n'indique si une dépendance possède une vulnérabilité connue.

Pipeline minimal recommandé

- Étape 1 : installation reproductible avec npm ci.
- Étape 2 : compilation CSS sans mode watch.
- Étape 3 : contrôle de syntaxe JavaScript et compilation de toutes les vues EJS.
- Étape 4 : lint avec ESLint.
- Étape 5 : tests unitaires et tests d'intégration avec une base PostgreSQL temporaire.
- Étape 6 : audit des dépendances et contrôle des secrets.
- Étape 7 : application contrôlée des migrations.
- Étape 8 : déploiement en préproduction, test de santé, puis production.

Améliorations proposées

- Ajouter les scripts npm build, lint, test, test:integration et migrate.
- Introduire un véritable outil de migrations avec table de suivi.
- Créer un workflow GitHub Actions déclenché sur chaque pull request.
- Protéger la branche principale et exiger la réussite des contrôles.
- Créer un environnement de préproduction utilisant une base séparée.
- Sauvegarder PostgreSQL avant les migrations de production.
- Ajouter une route de santé ne révélant aucune donnée sensible.
- Déployer une version identifiable et prévoir un retour arrière.

Niveau de priorité

Élevé dès que plusieurs personnes contribuent ou que le site est hébergé. Un pipeline minimal peut être créé avant même de choisir l'hébergeur.

Fonctionnalités pertinentes à développer

1. Fiabilisation des comptes

Ajouter la vérification de l'adresse e-mail, le mot de passe oublié et la fermeture des autres sessions. Ces fonctions sont plus importantes qu'une nouvelle fonctionnalité sociale, car tous les parcours réservations et Assaut de Bruay reposent sur les comptes.

2. Notifications utiles

Prévoir des e-mails pour les événements réellement importants : inscription à une table, annulation administrative, changement de statut d'une candidature, fermeture exceptionnelle de la salle et réponse à un message. Les préférences doivent permettre de limiter les envois.

3. Finalisation de l'Assaut de Bruay

Permettre au demandeur de corriger ou retirer sa candidature avant la clôture. Ajouter une demande de précision par l'administrateur, un résumé des besoins matériels et un export opérationnel des dossiers acceptés. Un export CSV devient pertinent ici, car il sert directement à l'organisation du week-end.

4. Statistiques associatives

Exploiter les archives existantes pour afficher l'évolution du nombre de participants, les jeux les plus joués, le nombre de tables utilisées et la fréquentation par période. Les statistiques doivent rester agrégées et éviter un suivi individuel inutile.

5. Galerie globale

Créer une galerie associative administrée, liée aux actualités ou événements, plutôt qu'une galerie par membre. Prévoir validation, compression, légendes, crédits et gestion du droit à l'image.

6. Accessibilité et qualité mobile

Effectuer une revue clavier, contrastes, libellés, focus des modales, messages d'erreur et tableaux sur mobile. Ajouter des tests Lighthouse et une vérification des formulaires avec lecteur d'écran.

7. Outils pratiques pour l'administration

Ajouter une recherche homogène, une pagination sur les grandes listes, des résumés matériels pour l'Assaut de Bruay et des notifications visibles sur le tableau de bord. Éviter de créer un rôle supplémentaire tant qu'un besoin réel de séparation des pouvoirs n'est pas identifié.

Feuille de route conseillée

Avant mise en production

- Retirer les documents internes du dossier public.
- Ajouter Helmet, HTTPS, trust proxy et permissions strictes des secrets.
- Mettre en place les titres SEO, descriptions, sitemap et robots.txt.
- Créer les premiers tests d'authentification, d'autorisation et de réservation.
- Automatiser la compilation CSS et les migrations.

Première version publique

- Ajouter confirmation d'e-mail et récupération de mot de passe.
- Mettre en place les notifications critiques.
- Finaliser la modification et le retrait des candidatures Assaut de Bruay.
- Ajouter les contrôles de santé, sauvegardes et supervision des erreurs.

Après stabilisation

- Construire le tableau de statistiques.
- Développer la galerie globale.
- Améliorer les exports et outils logistiques.

- Étudier une séparation de rôle uniquement si le fonctionnement du bureau l'exige.

Conclusion

Nord Stratégie dispose d'une architecture adaptée à son besoin et d'un périmètre fonctionnel déjà riche. Le meilleur investissement consiste maintenant à rendre ce socle observable, testable et sûr en production. Le SEO technique apportera de la visibilité locale, la CI/CD limitera les régressions et les prochaines fonctionnalités devront surtout simplifier l'organisation réelle de l'association.